3 INFORMATION SECURITY FRAMEWORK

The purpose of establishing an information security framework is to ensure that appropriate control mechanisms are in place to manage effectively the information assurance across the enterprise.

This chapter covers the basic principles for establishing such a framework within an organisation and will look at the general area of information security management. In particular it will consider the role and appropriate use of policy, standards and procedures, information assurance governance, security incident management and their appropriate implementation.

ORGANISATION AND RESPONSIBILITIES

LEARNING OUTCOMES

The aim of this section is to provide you with the basic knowledge needed to understand the principles for organising information assurance across the enterprise. Once completed, you should not only be able to define and explain the main concepts but also draft documents to meet the general requirements in the following areas.

The organisation's management of security

Establishing an organisational structure to manage information assurance provides a framework to ensure that the assurance requirements of the enterprise are understood and that responsibilities are allocated appropriately across the enterprise to achieve this. Accountabilities need to be clearly defined, whether at an enterprise level or on a local basis, and assurance activities need to be co-ordinated appropriately across the organisation to ensure that they are being managed effectively. This section covers the necessary organisational arrangements that should be carried out to provide effective control of information assurance.

Information security roles within the enterprise

There should be a nominated resource within the organisation that has responsibility for the day-to-day management of information assurance issues. This is to ensure that good information assurance practice is applied properly and effectively across the

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

enterprise and for co-ordinating all assurance activities. In larger organisations, this function should be a full-time role and the manager of this function is often referred to as the head of information assurance, the information security manager or the chief information security officer (CISO). In smaller organisations, the role may be combined with other responsibilities.

In this section the role will be referred to as the information security manager. How this role is structured will depend largely on the size and culture of the organisation and is typically supported by other people as part of a dedicated team.

The information security manager needs to understand the information security risks that the enterprise may face, what controls are in place and where the enterprise may be vulnerable. This information must be communicated effectively to senior management (who have ultimate responsibility for information assurance). This is to ensure that they understand the status of assurance within the enterprise so that the appropriate safeguards are put into place. The main activities of the information security manager are:

- co-ordinating information assurance activities across the enterprise, including those delegated outside the team;
- co-ordinating the production of security policy;
- communicating with users so they understand their information assurance responsibilities and are aware of potential threats to the enterprise;
- understanding the enterprise's risk appetite and profile and how it may be evolving;
- monitoring the effectiveness of the enterprise's assurance arrangements;
- reporting on the effectiveness of the assurance arrangements to senior management and suggesting improvements;
- providing expert advice on information assurance matters to the enterprise;
- creating a culture of good information exchange and assurance practices.

There are a number of recognised standards that provide guidance on how to manage assurance arrangements and responsibilities within an enterprise, such as the ISO/IEC 27000 series and the Information Security Forum (ISF) Standard of Good Practice.[1] These standards can be adapted to fit individual enterprise requirements.

Placement in the enterprise structure

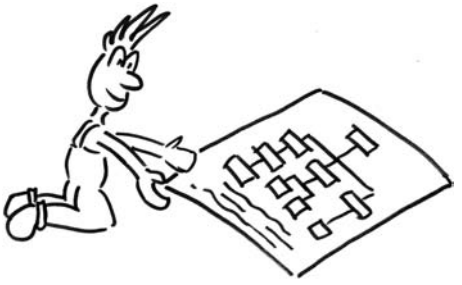
Placement of the various assurance roles within an organisation will normally depend on the structure, the particular requirements and the culture of the enterprise. Therefore, there are no definite hard and fast rules as to where the roles should sit specifically, how they should be organised or what their scope should include.

1 The latest ISF document at time of going to print, *The Standard of Good Practice for Information Security 2018*, can be found here: https://www.securityforum.org/tool/the-isf-standard-good-practice-information-security-2018/

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

In some enterprises, the information assurance function is located within the corporate compliance area. This is common in enterprises or industries that have a strong compliance culture, such as banking or manufacturing.



In other enterprises the function is based in the IT group because many (but rarely all) of the controls to protect the enterprise are reliant on computer technology. Sometimes, the function can be placed within a central facilities group since assurance responsibilities often span a number of management areas within an enterprise. To work effectively, reporting structures should include dotted line responsibilities to roles including, but not limited to, the chief risk officer (CRO), the senior responsible owner (SRO), chief information officer (CIO), senior information risk owner (SIRO) and the chief finance officer (CFO).

The scope of the information assurance function may vary. In some instances, the assurance function may include responsibility for setting policy and direction but not for the actual implementation of the security control mechanisms, which then may be carried out by a separate area such as the IT department or local teams. Alternatively, the assurance or audit function can also have responsibility for the implementation of technical security controls and solutions and for conducting investigations and monitoring compliance.

As a regulatory role, the information assurance function should be positioned as part of a formal structure so that it can facilitate the full management and co-ordination of assurance matters across the enterprise.

Board/director responsibility

One senior person within the organisation should be given the overall responsibility for protecting the assurance of the enterprise's information assets and be formally held accountable. This role should be performed by a board member or equivalent to demonstrate the enterprise's management commitment to information assurance. In some organisations, the CISO, or equivalent, is a board member. The main responsibility of this individual is to ensure that appropriate assurance controls are implemented across the enterprise and to:

- provide a single point of accountability for information assurance;
- ensure that assurance goals are identified and meet the enterprise's needs;
- ensure that adequate assurance resources are made available to protect the enterprise to an acceptable and agreed level of risk;
- assign specific assurance roles and responsibilities across the enterprise;
- provide clear direction, commitment and visible support for assurance initiatives, for example by approving and providing sign-off for high-level security policies, strategies and requisite architectures.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

The director has the necessary status to ensure that appropriate focus is placed on protecting the enterprise's information assets and to influence and sanction assurance activities. Implementing adequate assurance control mechanisms can in some cases be met with resistance from other parts of the business that are in competition for available resources, and therefore it is important to have a 'security champion' to ensure that priorities are met. Experience has shown that if senior support is not in place, assurance initiatives will probably fail.

There is an increasing quantity of UK and worldwide legislation and regulation that demands this level of accountability and responsibility, for example Sarbanes–Oxley (USA) and the Companies Act (UK). The Turnbull Report in the UK states that a board member for a public limited company has to be responsible for ensuring adequate service continuity requirements are in place to prevent the enterprise going out of operation after experiencing a major problem. The more recent legislative addition has been the European Union's GDPR incorporated into UK law alongside the Data Protection Act of 2018 that tailors how the GDPR applies in the UK. Another piece of European legislation, the Network and Information Systems (NIS) Regulations 2018, has a wide-ranging impact on organisations who are classed as 'operators of essential services' (OESs) and 'relevant digital service providers' (RDSPs).

If these measures are not appropriately implemented, that responsible person could perhaps face a custodial sentence or, in the case of GDPR, huge financial penalties that could be disastrous for an organisation. These potential outcomes may be good for focusing the attention of senior management and for securing appropriate resources. The director should establish and chair an ongoing high-level working group to co-ordinate assurance activities across the organisation to ensure adequate assurance measures are in place to protect the business to an acceptable and agreed level of risk, often referred to as the organisation's risk appetite.

This working group is often called a steering committee or a security forum. The working group should be made up of a cross-section of individuals from the enterprise that are either stakeholders in the requirement of good assurance or have responsibilities for ensuring appropriate assurance arrangements are in place. Membership should include one or more line of business (LOB) managers or departmental heads to ensure that assurance arrangements meet their business or organisational demands. It should also include the information security manager and representatives from vested interest parties such as internal audit, personnel (HR), physical security and the head of IT. In a world with increasing aptitude for outsourcing, it may be appropriate to include in the working group representatives from the key outsourcing partners to be present at meetings or perhaps at those non-commercially sensitive parts of meetings.

The group should meet regularly in order to ensure that the protection of the organisation's information is being managed effectively and that controls are in place to reduce risk to an acceptable level. This includes:

- ensuring that assurance is included in the enterprise's overall planning activities;
- approving and prioritising assurance improvement activities;
- reviewing assurance performance and changes in threats to assess whether the risk profile of the enterprise has altered;

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

- ensuring that all legislation and regulatory requirements are being met in an appropriate and effective way;
- approving policies, standards and procedures that relate to information assurance;
- acting as evangelists for assurance within the organisation by emphasising its importance to colleagues.

The director will normally delegate authority for the development of information assurance initiatives and responsibilities either to individuals within the working group or to other members of the organisation. However, the director will be ultimately accountable for achievements or failures. The working group is the cornerstone of the information governance structure that will be covered later in this chapter.

Responsibilities across the organisation

Achieving good information assurance requires teamwork and a wide variety of skills ranging from managerial to technical and administrative. It is unlikely that any one person would have all the requisite skill sets or even the time to perform everything that is required; therefore, roles need to be delegated to the appropriate teams or to specific individuals with the necessary skills. For instance, the skill sets required to maintain an enterprise's anti-virus systems are different from those required for administering user identities.

All those involved need to have a proper understanding of accountabilities and be given clear direction and support from senior management to achieve what is required of them. In many cases, individuals may be working together as a 'virtual team' that spans across separate management responsibility areas. For many individuals, their information assurance responsibilities will form just a part of their overall role. Therefore, their activities require co-ordination and monitoring from a central information assurance function to ensure they are successful. It is essential that all individuals have clearly defined responsibilities and that they understand their part in delivering the overall information assurance function within the enterprise. Their job descriptions or terms of reference should include:

- the scope of their responsibilities and their level of authority;
- the processes they should be following to carry out these responsibilities;
- the procedure they should carry out to report and deal with any security breaches that they discover;
- understanding confidentiality/non-disclosure constraints;
- requirements for regular reporting;
- what should take place if they leave the organisation;
- what will happen if they breach the agreed terms and conditions.

These responsibilities should reflect the enterprise information assurance policy and current legislation. They should be reviewed regularly to ensure that they remain current, are relevant and are supplemented with additional guidance as necessary. Where the information assurance function does not constitute a full-time role, it is important that

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

those engaged in carrying out assurance activities are given a clear mandate by senior management to do so and that the work is included as a formal part of their objectives. These individuals must have the sufficient skills and tools to be able to carry out these tasks and may need training and support to acquire the necessary knowledge and fully appreciate the critical nature of protecting information assets.

Many enterprises have local security co-ordinators that are the 'eyes and ears' at a local level to ensure that security policies are followed and for identifying any security vulnerabilities or breaches. They can offer feedback to the information security manager as to whether existing assurance processes and controls are effective, identify possible risks and help propose new assurance controls. The scope of the local co-ordinators will vary depending on the enterprise's requirements. In a large global operation it may be appropriate to have country or regional co-ordinators, or it may be more relevant to have an individual responsible for a business unit or office location. In the case of GDPR, it is a requirement that an organisation has a designated office or point of contact within the European Union (EU) if they come under the jurisdiction of the legislation. In smaller businesses it may be better to nominate individuals who have responsibility for a specific department or business function.

Anyone who has access to the organisation's information assets will have a level of personal responsibility for its assurance and it is important that these are known and understood. User responsibilities need to be clearly set out in an acceptable information use policy and bolstered by education to that they can help to protect against risk. Guidance on acceptable use policies is described in the next section and user awareness and training is described in more detail in Chapter 5. Individuals may have specific responsibilities for a particular application or system and in this case their responsibilities are best expressed in the system operating procedures. Third-party assurance responsibilities, particularly with outsourcing arrangements, should be included in contractual terms and conditions and should include appropriate auditing and monitoring arrangements.

Any information assets within an organisation should be associated with an owner of that information (i.e. head of department, business manager or process owner) who understands its importance to the enterprise and the resulting negative impact if its confidentiality, integrity or availability is compromised. This will help to ensure that adequate controls and procedures are put into place.

Statutory, regulatory and advisory requirements

External factors can influence how an enterprise's information assurance should be managed and these requirements need to be understood so that the appropriate assurance controls can be adopted to enable the business to fulfil its responsibilities. These requirements can arise from a variety of organisations such as the police, utility companies, government, trade regulatory bodies or telecommunications suppliers. They may be statutory, regulatory or advisory.

Statutory requirements are legal requirements that must be fulfilled. For example, law enforcement agencies must be contacted should certain laws be broken or are suspected of being broken – the download of child pornography would be such a case in many countries. Compliance with these requirements may influence how an enterprise's

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

incident reporting procedures are organised. For example, how, when and by whom should the authorities be contacted. Privacy legislation such as the GDPR will influence how information is stored and managed within the enterprise and how resources are deployed to ensure that the enterprise complies with this legislation.

Regulatory requirements are often imposed by trade bodies, and these specify how an enterprise should operate to conform to certain standards. Although they are not legal obligations, regulatory bodies have extensive powers and failure to comply could lead to possible fines or, in extreme cases, exclusion from trading in a particular environment. The finance sector is a good example of this as it maintains strict controls to prevent financial malpractices such as fraud or money laundering – official bodies, such as the Financial Conduct Authority (FCA) within the UK, have far-reaching powers. Another example of a regulatory authority in the UK with significant powers is the government agency on health and safety in the workplace. In terms of information, the Information Commissioner's Office (ICO) in the UK is the lead body for setting standards and then enforcing them across all sectors and they also act in an advisory role to other regulatory bodies (some termed 'competent authorities' under the NIS regulations) who have to concern themselves with information assurance. Some of these regulatory requirements support or supplement statutory requirements in certain business operations.

Advisory requirements may arise from government agencies or utility companies and provide advice as to what arrangements should be put into place to help cope with instances such as fires, natural disasters and acts of terrorism. These requirements are not legally binding and are generally issued to help encourage best practice.

Maintaining relationships with relevant external bodies is beneficial to an organisation as it helps the enterprise to better appreciate the requirements placed on them and gain prior warning of any changes. By understanding the requirements of the emergency services, utility companies and government agencies, enterprises can design their contingency plans and incident management processes and procedures more effectively.

Provision of specialist information security advice and expertise

Those involved in the security function should provide specialist security information advice and expertise to the enterprise. A high degree of current knowledge on information assurance matters should be maintained on topics such as awareness of industry trends, changes to organisational threats, new control measures, analysis of risk, legislation and compliance requirements and the latest technological developments. It is an ongoing process. It is not necessary to have all the answers, but it is essential to be in a position to know where to find this information or to have access to someone with this specialist knowledge as and when needed.

One way of achieving this aim is to keep in regular contact with special interest groups and websites or by networking with information assurance peers in other enterprises via professional associations or security forums. Information about new technologies, products, threats and vulnerabilities or how to tackle particular assurance issues can be shared with one another and often a collaborative approach is useful in understanding and addressing these issues before applying them to relevant situations. Bulletin boards, websites and news groups also can provide early warnings of possible alerts,

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

attacks and vulnerabilities and it is important to identify which ones may relate to the enterprise and which are a reliable source of trustworthy information.

A certain amount of ongoing self-education is needed to maintain this level of competency and to gain knowledge and understanding. Training courses are available to develop this knowledge with courses that range from specific topics on information assurance to training that covers a wider focus such as security management. Masters degrees, some approved by the NCSC, are available from a number of universities and some of them provide part-time or distance learning options. There are also several professional accreditations that can be gained to develop your knowledge and demonstrate the depth of your experience to others.

It is sometimes necessary to seek external security services. Larger information assurance functions are generally able to support larger teams with a wider range of expertise. However, even in large organisations it may be more appropriate and cost-effective to buy in specific expertise that is expensive to maintain and only needed occasionally. Forensic analysis or security penetration testing are typical areas where it is often more appropriate for an organisation to seek specialist external services. When selecting an external specialist, it is important to understand the skills being offered by the supplier and to seek assurance through accreditation, recommendations and references. For example, within the UK, the Council of Registered Ethical Security Testers (CREST) provide assessments of companies providing security testing services and individual testers. The NCSC has established a scheme, the Certified Cyber Security Consultancy, which certifies competent independent consultancy companies who offer information or cyber security advice and guidance.

Creating a culture of good information security practice

Information assurance needs the co-operation and collaboration of everyone with access to the enterprise's information. Involving everyone in the assurance process will help to develop a culture of good information security practice.

As previously mentioned, it is important that information assurance is taken seriously by senior management within the enterprise and that they provide sponsorship and support for assurance initiatives. If so, then their support and commitment will cascade down through the organisation. Line managers will proactively take responsibility for adopting information assurance measures within their teams, and likewise end users will know that they must take their responsibilities seriously. Positive reinforcement of good assurance behaviour by the information assurance function and senior management helps to cement good behaviour, and some organisations even include feedback on assurance behaviour in their performance reviews.

A key factor for success is ensuring that everyone that accesses the enterprise's information knows what is expected of them. Having in place clearly defined assurance roles and responsibilities, and up-to-date security policies and standards and procedures will eliminate any ambiguities. They do need to be clearly communicated and be readily accessible. For example, assurance responsibilities should be included in employee job descriptions and form part of third-parties' contractual conditions. All users need to understand clearly what will happen if they do not follow information assurance

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

policies and that senior management will be involved should the rules be breached. Policy development is covered in the next section.

Education is also a vital component in creating a culture of good information assurance practice. If everyone understands the value of the enterprise's information assets and how they can be put at risk, then they are far more likely to appreciate why these processes and procedures are in place. Regular awareness campaigns initiated through the information security manager can help to reinforce this message.

ACTIVITY 3.1

Ms Jackson has just returned from a conference and has realised that the enterprise does not have a formal information assurance function. She has asked you to put together a high-level proposal on what should be put in place for GANT.

ORGANISATIONAL POLICY, STANDARDS AND PROCEDURES

Organisations require their staff and third parties to use, manipulate and interpret information and need their co-operation to ensure that the information assets are accessed in a secure and responsible manner. All users need to know what the enterprise expects of them with regard to this. Policies, standards, procedures and guidelines provide this guidance.

LEARNING OUTCOMES

The intention of this section is to provide you with the basic knowledge needed to develop, write and gain user commitment for assurance policies, standards, operating procedures and guidelines. Following study in this area, you should be able to explain and justify not only the main concepts but also to draft documents to meet the general requirements in the following areas.

Developing, writing and getting commitment to security policies

One senior person within the organisation should be given the overall responsibility for protecting the assurance of the organisation's information assets and be formally held accountable to ensure that appropriate security controls are implemented across the business. This director should be supported by a working group to ensure that adequate assurance measures have been put in place to protect the organisation to an acceptable level of risk. Involving senior management will help to endorse the governance process, ensure that adequate resources are made available, ensure that controls are implemented effectively and that any identified security gaps are addressed.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

Developing standards, guidelines, operating procedures and so on

There is often confusion concerning the definition of policies, standards, procedures and guidelines, so this should be clarified first of all.

A policy is a high-level statement of an organisation's values, goals and objectives in a specific area, and the general approach to achieving them. Although they should be regularly reviewed, policies should hold good for some time as they are not intended to provide either detailed or specific guidance on how to achieve these goals. For example, a policy might say that each user is responsible for creating and maintaining their system passwords – although it doesn't say exactly how to do this. Policies are mandatory.

A standard is more prescriptive than a policy. It quantifies what needs to be done and provides consistency in controls that can be measured. For instance, passwords must contain a minimum of eight characters, be a mix of numbers, letters and special characters and be changed if compromised or for other similar reasons. Compliance with standards is also mandatory. They should support policy and state what 'must' be done and how it should be achieved. Standards can be either general (e.g. handling sensitive information) or technical (e.g. encryption of data), but they should always relate to a specific subject.

A procedure is a set of detailed working instructions and will describe what, when, how and by whom something should be done. Again, they are obligatory and should support enterprise policies and standards.

Guidelines are not mandatory, but can provide advice, direction and best practice in instances where it is often difficult to regulate how something should be done (e.g. working practices when out of the office).

Whether producing policies, standards, procedures or guidelines, these documents should always be clearly written and to the point. Language should be concise, unambiguous and as free as possible of complex jargon and acronyms. Statements should contain positive rather than negative 'do not' rules, as these tend to make users less responsive. A document should address a clear and well-defined subject area within its scope so that the target audience knows that it is relevant to them (e.g. 'this policy applies to all GANT employees in the UK').

Policies, and any attendant standards, procedures and guidelines, should be endorsed by senior management and have clear ownership (i.e. head of Human Resources, departmental manager, etc.). In addition to senior management, they should also be supported by the main stakeholders and especially those people tasked to enforce them. For example, if an individual is to be disciplined for a breach of policy, then Human Resources will need to support the policy to carry out any disciplinary action in relation to it. To have credibility, policies should be endorsed by all interested parties such as stakeholders and user communities.

Policies, standards and procedures need to be realistic and enforceable. It may be a great aspiration to expect people to keep their laptops with them at all times, but it is far more realistic to state that they must not be left unattended in a public place. Similarly, if a technical control is stipulated (e.g. encryption of all data on laptops) it

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

must be anticipated whether this is actually feasible. There may be instances where it is not possible to comply with policy and consideration also needs to be given to allowing exceptions to policy in the way of special dispensations.

To be enforceable, policies must be consistent with other corporate policies and compliant with the law. All users need to know what will happen if they do not comply. Policies need to be regularly reviewed to ensure that they remain current, relevant and effective. This will be covered in more detail later in this chapter under 'Information security governance'.

The way in which policies, standards, procedures and guidelines are structured will largely depend on the organisation. Regardless, every organisation should have a (high-level) assurance policy that states the organisation's commitment to information assurance and what it expects to be done to protect its information assets. A security policy is a strategic statement of the organisation's approach to assurance and sets out the formal organisational stance on assurance matters for everyone to see. This security policy should contain statements on:

- how the enterprise will manage information assurance;
- the protection of information assets in accordance with their criticality;
- the compliance with legal and regulatory obligations;
- the means by which users will be made aware of information assurance issues and the process to deal with breaches to policy and suspected assurance weaknesses;
- the fact that this policy has the support of the board and chief executive.

More detailed guidance on what to include in a security policy can be found in recognised standards such as the ISO/IEC 27000 series and the ISF *Standard of Good Practice*. The high-level security policy should be signed off by the director responsible for information assurance. The policy should then be issued or made available to all individuals with access to the organisation's information and systems, both internal and external, in a format that is readily understandable and accessible by the user.

Third parties often require access to an enterprise's information assets in terms of processing information, offering support, providing services or processing facilities. It is important to ensure that there is no misunderstanding between the enterprise and the third party over what controls are to be put in place to protect the enterprise's information assets. Policies, standards and procedures should be extended to third parties where relevant, and specific policies may need to be written to cover third-party arrangements. These should be included within the terms of a contract. Access should not be given to an external entity until the enterprise can be assured that the appropriate controls have been put in place and that the third party has formally confirmed that they understand their obligations and accept their responsibility to comply.

As the relationships with third parties can be quite diverse and extensive (as in the case of outsourcing), any terms associated with policies, standards and procedures may vary according to the type and nature of the relationship. Agreements with third parties should include the enterprise's assurance policy. Again, the ISO/IEC 27000 series and

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

the ISF *Standard of Good Practice* contain guidance on the type of controls that should be considered for inclusion in third-party agreements, but typically they should include the following arrangements:

- management of changes to the application/facility/service/resource;
- the right to audit and monitor assurance arrangements within the third party;
- notification and investigation of assurance incidents and security breaches;
- the timely sharing of relevant cyber security information and knowledge;
- recruitment of personnel.

Care should be taken to ensure that sensitive information is not disclosed to or by third parties, and policies should reflect demands on the third party for confidentiality and non-disclosure of information. The third party may, in the process of delivering the service, use further subcontractors or service providers. It is important, therefore, to ensure that any policies, standards, procedures and guidelines are applied to them too and this can be controlled in the contract.

Balance between physical, procedural and technical controls

Physical, procedural and technical controls (often termed operational types of control) can provide very effective security mechanisms and do much to reduce the likelihood of incidents occurring. However, they each have their limitations and there are occasions when their use is not appropriate – possibly their deployment would be far too complex or expensive given the perceived value of the information and the associated risk. For example, a £1 million security application to protect a £10,000 information asset does not make much financial sense. In other cases, a physical or technical control may be so intrusive that the users are prevented from carrying out their work efficiently. In many cases there may be no reasonable physical or technical controls that can be deployed to prevent a particular security breach from occurring or it may be that the security controls in place can be circumvented by the user in some way.

Users need to access information systems in order to carry out their tasks and this inevitably introduces a level of risk to the information. They may need to share this data with colleagues or external suppliers and make value judgements as to whether it should be released to them. Reducing this kind of risk is difficult to achieve through technical controls alone. Technical controls introduced by a documental security system, for example, may well provide a good level of security. There will, however, always be exceptions, and these need to be handled in a consistent manner by having a policy and process in place. This might simply involve informing a senior colleague of the issue and the proposed course of action to deal with the issue in the short term.

Formal policies and procedures can be used to make users aware of their responsibilities and the risks relating to the data to which they have access. The policies can empower individuals to make decisions as to whether others should access this data. This can be an effective control measure, but is obviously dependent upon users complying with these policies and associated standards and procedures.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

Occasionally, due to time pressures, or perhaps because of expediency, policy rules may be circumvented or ignored. Ignorance or a failure to properly understand the policy will prevent compliance, and in these instances users won't understand the risks to their information assets and are very unlikely to be fully aware of the threats to them. Policies and procedures rely on individuals knowing that the policy exists and understanding what the policy expects of them as well as their agreement to comply with it. So, policy controls have limitations.

There needs to be a sensible balance between using physical, procedural and technical controls to manage the risks associated with information assets. All three elements should be used to complement one another in a layered approach to manage risk to an acceptable level.

Defence in depth and breadth

These principles are a critical instrument that must be fully appreciated and, where appropriate, implemented if security is to be established and maintained effectively.

The principle of defence in depth is that there are layers of security that build on one another. Today it is virtually impossible for any organisation, large or small, to protect all their information assets to the highest degree possible. One reason is that of cost, but there is also a more practical reason: whereas some information assets need to be freely available to staff members in order for them to undertake their routine daily work activities, other information is far more critical and sensitive and so must be afforded a high level of protection, thereby almost certainly making it more difficult to access and use.

Defence in breadth is a more recently coined phrase that has come about due to the need to consider all the connections to any networked system. The complexity of the networks now in place in many organisations is staggering and, when connections to suppliers, customers, different physical locations around the world, homeworkers and many more are considered, they become ever more difficult to manage. The concept of understanding the breadth of the network and its connectivity is critical since, as the old adage says, the weakest link of a chain is where it will break. The part of the very complex network that has the lowest level of security will be where the criminal or other intruder will find their way in. Malware is now very sophisticated software and it has the capacity to find ways of traversing a network to find holes or legitimate portals into other areas that, because it is already inside the network, might, for example, allow the intruder to be seen as a trusted user.

End-user code of practice

The development of a high-level security policy should be bolstered by an end-user code of practice or acceptable use policy that provides a readily accessible way of communicating requirements to end users. An acceptable use policy demonstrates the organisation's commitment to information assurance and must be approved by the director responsible for information assurance. It should be published to all users that need to access the organisation's information management systems and include all employees (permanent and temporary, full- and part-time), contractors and third

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

parties. The acceptable use policy should detail what is expected from users to protect the organisation's information assets. Elements that may be included in this policy are:

- ensuring that user passwords and PINs are protected appropriately, are not compromised and are changed at appropriate intervals;
- ensuring that users only access information, facilities or equipment for which they have the designated business need and requisite authorisation;
- logging-off from systems when leaving a workstation unattended;
- locking away sensitive documentation and media when not in use (as part of a clear desk policy, for example);
- use of personal devices such as smartphones and tablets;
- ensuring that all security incidents are reported.

An acceptable use policy can also include general statements regarding behaviour in the workplace, such as making it unacceptable to make any sexual, racist, obscene, discriminatory, harassing or other offensive statements regardless of the method used to transmit such statements (email, instant messaging, telephone, text, paper or spoken word). All conditions of employment for permanent or contract employees should contain a statement that compliance with the enterprise information assurance policies is mandatory. To avoid vicarious liability, the policy should also include statements that specify that users must comply with all appropriate legal and regulatory requirements placed on the organisation.

Consequences of policy violation

Anyone accessing the organisation's information assets needs to know what the consequences of a policy violation are, and this should be clearly stated in the policy, standard or procedure. Appropriate processes should be established for reporting and dealing with violations so that they are dealt with in a consistent manner. These processes should be documented and agreed with the relevant stakeholders when the documents are produced.

Violation of a policy may, in severe cases, lead to an employee disciplinary process being instigated, termination of supplier contract or the need to report the behaviour to the appropriate law enforcement agency. Therefore, the rules and processes need to be understood, agreed and put into effect within the organisation before violations may need to be dealt with. Naturally it is essential to involve the HR and legal departments in the development of such policies to ensure the proposed course of action complies fully with all employment legislation as well as other relevant national laws.

However, it is a waste of time having a policy in place unless the organisation is prepared to enforce it. Senior management, and those that have to enforce the rules, need to support the processes to deal with any violations. If violations have not been dealt with appropriately, or have been ignored by line management, then this should also be considered as a violation of policy and treated seriously.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

ACTIVITY 3.2

Ms Jackson has asked you to prepare an end-user code of practice for GANT. Identify the main areas that you would include in the policy.

INFORMATION SECURITY GOVERNANCE

There is an increasing amount of legislation and regulation that requires senior management to ensure that adequate controls are in place to protect the enterprise's information assets. To fulfil these obligations, senior management needs to understand the current status of existing assurance controls, where such controls are inadequate and how the risk profile of the organisation is changing. The necessary effort can then be made to improve security mechanisms and manage the risk effectively. This section covers the principles of the governance processes that should be implemented to enable this to happen and to provide senior management with sound and up-to-date information on the state of assurance within the enterprise.

LEARNING OUTCOMES

The intention of this section is to provide you with the basic knowledge needed to understand the principles of information assurance governance. Once completed, you should be able to explain and justify the main concepts and establish procedures and draft documents to meet the general requirements in the following areas.

Review, evaluation and revision of security policy

The production of policies, standards, procedures and guidelines has already been covered in the previous section, but to ensure that they remain current, relevant and effective they should be reviewed regularly. Reviews should take place after any significant changes to either systems or resources or as part of a regular review schedule (e.g. annually).

A management review process should be established to ensure that policy reviews take place in an organised and timely manner. The review schedule should identify all the persons to be involved and a formal record kept of any revisions made – with an explanation as to why content has been incorporated, altered or removed. Senior management should then approve the final version of any amended documentation.

The review should involve all the main stakeholders, including external parties and, where applicable, regulatory authorities. The review should focus on factors that might influence or trigger possible amendments, such as:

- changes to technology, processes, organisation, resource availability or working practices;

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

- changes to contractual, regulatory or legal requirements;
- changes in threats and vulnerabilities;
- results, actions and recommendations from any assurance reviews or audits;
- findings and recommendations from either incidents or previous assurance breaches, or where there is evidence of non-compliance with the policy.

Once the review has been completed the revised policy should be communicated effectively to the relevant users, both internal and external to the organisation. This process should also be used for the maintenance of all other assurance documents, such as security standards, procedures and guidelines.

Security audits and reviews

Audits and reviews provide a good opportunity to understand how well things are working within the enterprise and provide senior management with valuable information on the assurance of their environment. Regular independent assurance audits and reviews should be carried out across the business to ensure that its information systems are compliant with existing security policies, standards and controls. Possible vulnerabilities to these systems can be checked and the effectiveness of existing controls can be tested. Audits and reviews should be carried out periodically or when a significant change (e.g. a system upgrade, new threat or vulnerability, a change of risk appetite, etc.) has occurred.

To introduce a measure of impartiality into the review, it should be carried out by an independent party, which will also bring to it a fresh set of eyes. Ideally, a member of an audit team or a manager that has no conflict of interest in its outcome could do this. Alternatively, reviews can be carried out by a third party such as an external auditor or a consulting company. In the case of technical reviews, it is often beneficial to engage a company with specialist knowledge in areas such as penetration testing. They can bring with them their experience of having audited similar assurance-based scenarios in other organisations. Reviewers must have sufficient expertise, so it is prudent to verify their abilities before commencement. Technical testing should only be carried out by recognised and approved technicians and engineers. Any organisation providing testers should also be able to verify that the individuals' CVs and background have been checked to ensure that they have a suitable level of personal integrity. Information on technical testing and assessment is covered in more detail in Chapter 6.

A programme of information assurance audits and reviews should be introduced by senior management. The scope of each individual review and their deliverables should be agreed by senior management and the area owner (i.e. head of department, line manager, etc.). A scoping exercise should be completed before the audit or review is started and a checklist should be developed to measure the efficacy of the assurance controls. The outputs should show whether the defined controls (e.g. policy, standard, procedural or technical) have been implemented correctly and are effective enough to reduce risk to an acceptable level.

Access rights to systems or information assets for those performing the audit or review should be restricted to only what is necessary on a need-to-know basis. These should be monitored and logged to create a reference trail of their activities. Wherever possible, auditors and reviewers should be given read-only access to isolated copies

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

of the system. Audit tools should be restricted to prevent any possible misuse or compromise of data. The legal implications of providing third parties with access to sensitive information should be considered, as should the disposal of any information, reports and scripts that result from the audits or tests. NDAs should be put in place if the information being reviewed is sensitive, as will often be the case. Audits and reviews should be planned well in advance to minimise the risk of disruption to the normal operation of the enterprise. Some audits, such as penetration testing, may produce some unexpected activity on a computer system or network. Change management processes should be followed to ensure that all parties that could be affected are aware of the planned activities and potential change in activity levels.

The results of the audit or review should be recorded within a formal report and presented by the reviewer to senior management and the manager whose area has been reviewed. A plan of corrective action should be agreed with them, including timescales for implementation. The plan should be monitored regularly to ensure that actions are being progressed. Any risks identified during an audit or review should always be added to an information risk register, maintained centrally by the organisation. All documentation produced should be filed securely so that it can be referred to when planning the following cycle of audits and reviews.

Checks for compliance with security policy

Regular checks should be carried out to measure compliance with security policies, standards and procedures. Carrying out compliance checks helps to identify whether controls are still adequate and relevant. Compliance checks also help to gauge the level of user understanding and awareness of their assurance responsibilities and whether or not these are being taken seriously. If regular checks are not carried out, then over time there can be a tendency for users to show less regard for them. Assurance is weakened as users become aware that monitoring does not take place and that they are not likely to be challenged.



If an instance of non-compliance has been identified, then it is necessary to discover why this has happened. This could be due to lack of training, misunderstandings or perhaps simple disregard of procedures. It may have resulted from a change in business processes that has not been recognised in the assurance documentation. The compliance checker must then decide what action should be taken and whether measures need to be put in place to prevent further occurrences. Action taken should reflect the scale of the non-conformity; minor incidents, such as an isolated instance where a procedure has not been followed, could be dealt with in an informal manner, but any major non-conformance, such as widespread password sharing, should be addressed more formally. If corrective action is recommended, subsequent reviews should identify that it has been implemented.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

The results of compliance checks should be recorded and serious instances of non-compliance reported to senior management. The findings from the checks can be fed into subsequent policy reviews. Compliance reviews should also be carried out to ensure that the enterprise is using licences, for example for software, in accordance with terms stated in the purchase agreement.

Reporting on compliance status

The finance industry has a long history of regulation and most stock exchanges have their own regulatory controls to prevent financial malpractice, but governance controls have gradually extended to other operating spheres. Many countries have produced their own codes of ethics, often in response to large corporate failures or in response to public pressure. The Sarbanes–Oxley Act was introduced in 2002 following a number of high-profile financial accounting scandals in the USA. The EU's governance legislation was revised in 2004 via the Companies (Audit, Investigations and Community Enterprise) Act, which has been implemented across the member states and has replaced most of their local company legislation.

The type of strategy deployed by the enterprise to meet their information assurance compliance obligations will depend on the risk appetite of the organisation and the external requirements placed on them. The enterprise needs to understand what their specific obligations are so they can implement the necessary controls and reporting mechanisms. In some situations, tightly specified governance requirements do apply, but mostly they ask the enterprise to demonstrate that good information assurance controls have been implemented. Generally, regulators will want assurance that senior management are committed to protecting the enterprise's information assets, understand the enterprise's risk profile and have implemented controls to manage risk to an acceptable level. Regulators will also want assurance that the controls in place are working effectively and that any gaps identified are being addressed.

Senior management and any regulatory or compliance bodies need to have access to sufficient information to be able to demonstrate compliance. To do this, the following types of information need to be made available:

- high-level risk assessments for the enterprise and for critical systems and services;
- a risk register showing how identified risks will be, and are being, managed;
- an up-to-date set of security policies with a review process;
- a register of any dispensations from security polices;
- the results from assurance reviews and security testing and compliance reviews;
- reports from any assurance breaches or incidents, including any actions taken;
- plans to address any compliance weaknesses.

The relevant information has to be gathered, reviewed and presented in a format that is acceptable to the regulator. This activity can be very time-consuming, so it helps to develop a repeatable and efficient process for reporting on compliance issues and to

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

reuse controls for each of the regulatory groups. This process may form part of an enterprise information assurance policy.

There are various models (comprising a methodology, structure and processes) that can be adopted by an enterprise to provide this level of information. All the models tend to be based upon the principles of implementing a formal control process for:

- understanding risk;
- identifying control requirements to reduce risk to an acceptable level;
- implementing effective security controls;
- monitoring how effective the controls are;
- periodic re-evaluation of risk levels;
- the efficacy of controls to enable continual improvement and to ensure that the risk level is maintained.

Current models include ISO/IEC 27001, Security Operations Maturity Architecture (SOMA) and the Committee of Sponsoring Organizations of the Treadway Commission (COSO), and they all offer levels of accreditation to enable the enterprise to demonstrate their competency to other organisations and regulatory bodies. The ISO/IEC 27001 model provides an approach for establishing, implementing, operating, monitoring, reviewing, maintaining and improving assurance within an organisation. This is known as the 'Plan–Do–Check–Act' (PDCA) or Deming Cycle approach to provide a cycle of continuous assurance review and improvement, although it is no longer part of the ISO/IEC 27001 standard.

SOMA, produced by the Institute for Security and Open Methodologies, provides a framework for measuring the operational security and management process and is structured in maturity levels that can be adapted to work at different levels of assurance maturity within the enterprise as well as being used with other standards. COSO, produced by the Treadway Commission, provides a framework for evaluating effectiveness of assurance by establishing a set of objectives for assurance control and measuring against them. This is often used for testing the effectiveness of accounting controls. There are many more such standards and frameworks, some fairly generic, such as those from the USA in the series of standards issued by the National Institute of Standards and Technology (NIST), and others targeted at specific industries or activities, such as the Payment Card Industry Data Security Standard (PCI DSS) requirements that govern the acceptance of payment cards.

ACTIVITY 3.3

After the recent loss of information, Ms Jackson is concerned that she needs to demonstrate to the regulators and external auditors that good assurance controls are in place within GANT. How would you provide her with evidence to demonstrate that assurance is being managed effectively?

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

INFORMATION ASSURANCE PROGRAMME IMPLEMENTATION

An information assurance programme provides a high-level view of how the organisation will address its assurance needs. It can help to develop a common understanding of information risk and enable the organisation to prioritise and focus on implementing controls that address the risks that matter most. This section looks at various aspects of assurance planning and how to implement an assurance programme within an enterprise. It is not intended to offer guidance on either project or programme management. There are many publications that address this subject, including the BCS publication *Project Management for IT-related Projects* (Hughes et al. 2019), which provides the textbook material for the BCS Foundation qualification in IS Project Management.

LEARNING OUTCOMES

The intention of this section is to provide you with the basic knowledge needed to understand the principles of how to implement information assurance measures within an enterprise. Once completed, you should be able to define and explain the main concepts and also draft documents to meet the general requirements in the following areas.

Planning – ensuring effective programme implementation

Good planning is the foundation of any successful information assurance programme implementation. It can be used as a powerful tool for gaining support from both senior management and key stakeholders and to demonstrate how the assurance programme is helping to reduce risk within the enterprise. This builds support for further initiatives.

To have credibility, an information assurance implementation programme has to be realistic, be achievable and to address accurately the needs of the enterprise. A programme will need to fulfil agreed objectives within the timescales set, and to demonstrate quality, value for money and overall benefit to the organisation. A programme usually consists of a number of projects, with each addressing either a function, application or information asset.

When planning a programme implementation, it is necessary to understand the current status of assurance within the enterprise and what the programme needs to achieve. Ideally, a prior risk assessment should have been carried out. The outputs will help to define and shape the implementation programme and provide justification as to why it should be delivered. Guidance on carrying out a risk assessment is covered in Chapter 2.

Work should be prioritised to deal with the most pressing issues. A mix of tactical and strategic approaches may be used to address the issues involved. If possible, try to identify where there are some quick wins to be achieved. Those that have a high probability of success using only minimal resources will do much to raise the overall credibility of the implementation plan within the organisation.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

When planning an implementation, consideration should be given to how long it will take to implement controls, how easy the implementation will be, what the associated costs are and a measure of the appetite of the organisation for wanting to resolve these issues. The main steps to developing an implementation programme and plan are to identify:

- how the implementation programme will address risks within the enterprise and reduce them to an acceptable level;
- the potential benefits of undertaking the programme;
- the controls or work streams that need to be set up to achieve this;
- the level of effort that will be required and from whom;
- who will be accountable for each part of the programme;
- the costs and timescales associated with implementation;
- how progress will be tracked.

High-level support is essential to the success of the programme and it should always have a senior responsible owner (sponsor). The programme and approach should be agreed with the main stakeholders and signed off by the sponsor. A steering committee should be set up to track the success of the programme and deal with any issues that arise. Resource and budget will need to be secured before the programme starts.

Depending on the scale and size of the programme, it may be necessary to split it into a series of separate projects each with their own planning and tracking mechanisms. During the course of the programme there may be a need for planning revisions due to changes in enterprise priorities, budget cuts, unavailability of key human resources or similar. Such factors might affect what can be achieved; therefore, the overall plan should be kept at a high level with its key deliverables and main milestones clearly expressed, allowing the progress of the programme to be monitored readily. Detailed planning should be carried out near to the time of implementation where there is greater certainty of a settled environment and an appropriate understanding of what needs to be done at that point.

The plan should focus on the key deliverables and work should be divided into manageable amounts that can be measured (milestones). Unless human resource is fully dedicated to the project, it may be necessary to calculate how much of a person's time has been committed to it. Project work can be allocated accordingly and enable resources to meet both project activities and other commitments.

The project plan should be regularly reviewed. The frequency of the reviews will vary depending on the type of implementation (daily, weekly, monthly). The purpose of these reviews is to maintain a vision of its actual progress by understanding what has been achieved thus far, comparing progress against the schedule, handling variations and revising the plan, identifying problems and applying corrective action. Progress should be reported regularly to both the programme sponsor and any stakeholders, and review meetings should be set up to enable them to agree and support programme alterations to meet changing requirements.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

How to present information assurance programmes as a positive benefit

An information assurance programme should be seen as delivering positive benefits to the enterprise. Managing down information risk can bring about tangible benefits in terms of greater stability of information systems and improved protection to sensitive information. These benefits can show the rest of the organisation that assurance priorities are aligned with the priorities of the enterprise.

Communicating with senior management, line managers and general users in a manner that relates to their own particular interests can do much to change the view that the assurance function is an inhibitor to a view that it is an enabler by demonstrating how it can add value to the organisation. Similarly, establishing good interpersonal relationships with stakeholders and colleagues in general will always help to present assurance programmes as a worthwhile activity. It is essential to be sensitive to their needs and ensure that they understand what the programme means specifically to them and how it will affect their role. Initially, colleagues may be wary of an implementation programme. Including them within the planning process will help to gain their confidence and appreciation. By aligning assurance objectives with the overall enterprise culture and values it can be seen that you are working collaboratively to achieve the same shared goals.

As with all initiatives, it is essential to have the support and commitment of senior management. Usually, they are not assurance specialists and do not have a full understanding of the information assurance risks and issues facing the organisation. It is important to present the positive benefits of the assurance programme in a manner that is concise and free of jargon. To support the programme, senior management needs to understand:

- the risks facing the organisation;
- the cause and potential impacts of these risks;
- the benefits they will see from their investment;
- where there may need to be changes to ways of working;
- how they can support or sponsor the programme.

The programme should be formally presented to them by way of a sound business case and be accompanied by all the necessary facts to enable an informed decision to be made. Senior management is generally more favourable to persuasion if they can realise a return on their investment. By quantifying impacts and explaining where the enterprise may be vulnerable, it is possible to demonstrate that a reduction in impacts can lead to a reduction in operating costs. Return on investment (ROI) is a mechanism that can be used to justify assurance expenditure and gain budget approval.

By calculating a positive financial return on an assurance investment, it is possible to put forward a persuasive case for its implementation by balancing potential financial rewards against the costs of implementing the controls. This is achieved by calculating how much it would cost to purchase and implement a particular security control and then estimating, in cost terms, what expense the organisation could incur as a

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

result of assurance incidents. Demonstrating that good assurance controls can be used by the enterprise for competitive advantage can also help to present assurance programmes as a positive activity. For example, many organisations insist that an enterprise has certification to particular security standards, such as ISO/IEC 27001, as a prerequisite before they engage with them. This provides them with an assurance that the enterprise has implemented effective assurance controls. Enterprises that have had assurance breaches can often suffer financially through fines and lost business as their trading partners and customers lose confidence in their abilities to protect their information. For some organisations a security breach can have an enormous negative impact on their brand value. A low instance of security breaches and good assurance controls in place can provide commercial advantage over less conscientious competitors.

Security architecture and strategy

Information security strategy and architecture are two concepts in information assurance implementation that have gained credibility and value in recent years. This section will look at some of the high-level principles regarding these concepts.

An information security strategy is a plan to take the assurance function within an organisation from the reality of where it is now with all its problems and issues, to an improved state in the future. It provides a road map or vision as to how this can be achieved and how it will support the organisation going forward. A strategy should normally cover a period of time where it is possible to implement a significant level of change but short enough to be able to predict changes in technology and organisational objectives. Typically, this is over a three- to five-year period.

An information security strategy has the elements of an implementation programme, but covers a longer period of time and is pitched at a much higher, less detailed level. It should demonstrate how it will enable the enterprise to achieve its objectives and how it will protect it against current and future threats. It should consider:

- the current state of assurance and the strengths and weaknesses of existing controls;
- how the risk profile of the enterprise is likely to change in response to changing business objectives and working practices;
- trends in threats and vulnerabilities to potential types of incidents;
- expected developments in software and hardware;
- legal, compliance and audit requirements and any anticipated changes;
- areas where cost savings can be made.

As it is a vision, this high-level document should be written in concise non-technical language so that the target business audience can clearly comprehend the bigger picture and the vision being presented. The strategy should remain a living document by being regularly reviewed and updated to reflect changes in technology and organisational priorities as they are likely to change over the period of its existence.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

Having a strategy in place shows a degree of maturity of the information assurance function within the organisation. It provides an assurance that the organisation is committed to good information assurance governance. Increasingly, there are pressures exerted from external bodies (via legislation and regulation) for organisations to have a security strategy in place.

The second concept is of information security architecture that can be used in conjunction with the information security strategy. The architecture translates organisational requirements for assurance into a set of controls that can be used to protect the enterprise's information assets. The information security architecture should aim to provide a common and consistent framework of global assurance controls and arrangements to be used across the enterprise rather than in a piecemeal fashion. Traditionally, IT-based architectures are focused purely on technology, but, as information assurance behaviour extends beyond technology to include policies, processes, procedures and user behaviour, so it follows that an information security architecture should also encompass these aspects.

An enterprise information security architecture should provide system developers and administrators with a consistent framework of assurance controls that can be used across multiple systems and environments within the enterprise. It can be adapted to fulfil different circumstances, which means that effort is not duplicated every time a new set of controls is implemented. Efficiency and productivity can be increased, while costs can be reduced by providing leverage and economies of scale. This should enable the assurance function to react more quickly to commercial, organisational and technological changes and be able to implement assurance solutions more quickly, efficiently and at lower costs.

It also supports the concept of defence in depth, where layers of security can be implemented such that only the most valuable or sensitive information is afforded the highest protection, a pattern for security sometimes called the onion model. The idea of defence in breadth can also be covered by information security architecture if the bounds of the organisation are extended, in terms of the information security aspects at least, to include key partners and suppliers. This would mean an organisation setting out their terms and conditions for the security of connections of systems and other logical interactions. These are sometimes referred to as code of connection or CoCo.

An information security architecture works on a set of 'principles' that express the type of controls to be implemented. They act as positioning statements that will be adopted within the architecture. An example of this is 'auditing and monitoring controls will ensure that the organisation complies with security policies and legal obligations'. Having identified a set of principles, the architecture can then be modelled through increasing layers of complexity and detail, starting at a high-level conception view of controls though to a detailed specification and design.

Components within the enterprise with similar security requirements can be grouped together into 'domains' so that common sets of security controls can be developed to protect them. For example, all enterprise systems with web-enabled interfaces can use the same domain controls. The term 'services' is used to describe the type of controls that will be used to protect these components.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

The need to link with business planning and risk management and audit processes

The aim of an information assurance programme should be to reduce information risk within the enterprise. As we have seen throughout this section, information assurance planning and implementation processes should not work in isolation. To be effective, an implementation programme needs to understand the enterprise's business objectives and goals so that it can identify the appropriate assurance control measures to ensure that the enterprise is sufficiently protected to meet these goals.

Information assurance implementation programmes need to work closely with other organisational and assurance processes to manage risk to an acceptable level. The risk management process should provide awareness and understanding of the risks faced by the enterprise and identify where risks are not being managed effectively. The outputs from risk assessments should determine what controls must be implemented and assess how urgently they need to be addressed.

Similarly, assurance governance processes will identify where existing controls are inadequate and where improvements need to be made. This may be through the reporting of assurance breaches or via auditing or testing of security controls. Governance processes will also determine changes in regulatory or legal requirements that may require additional controls to be put in place.

All implementation programmes should support the enterprise's information assurance policies, security strategy and security architecture. All security controls should support its long-term vision for information assurance and should be seen to add value or business benefit to the organisation.

ACTIVITY 3.4

Ms Jackson is very pleased with the work that you have done so far on information assurance and has given you a budget to implement some additional access controls within GANT. How would you approach this?

SECURITY INCIDENT MANAGEMENT

No matter how good an organisation's risk assessment and the controls that have been implemented, and regardless of how careful the organisation is in conducting its day-to-day business, security incidents will happen. It's not *if*, it's a case of *when* and *how often*. People make mistakes, systems malfunction and there are zero-day attacks that will defeat the best security tools. Organisations that have good information security maturity recognise this and then plan and train for it.

Security incidents don't just affect the confidentiality of data. The impact can equally relate to the integrity or availability of data or any other asset employed by the organisation or provided by a third party (such as cloud services). It is important to have

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

plans in place to deal with the most likely eventualities before they happen. Trying to think of and implement solutions after the event is much more difficult, will take longer and is more risky in terms of them not working, not to mention bringing additional costs. Planning in advance also means a very hard question from the senior management, 'Why didn't we have a plan to deal with this?', can often be avoided.

LEARNING OUTCOMES

The intention of this section is to provide you with the basic knowledge needed to manage security incidents and to plan and conduct a forensic investigation. Once completed, you should have formed an understanding of the following concepts.

Security incident reporting, recording and management

Having an incident response plan that has been worked out in advance and tested is like having a good insurance policy. Trying to obtain one after the event is too late. Do not think that it is possible to improvise something quickly, because this is a complex subject with a lot of variables. In the ensuing chaos, distractions and pressure to recover to normal operations, the organisation will not have the luxury of time to come up with a good plan, train people and test it thoroughly. Evidence shows that more than half of incident response plans fail when first tested.

A security incident response plan is a set of instructions to help the organisation, and the incident response team in particular, to detect, respond to and recover from information security incidents. These types of plans address issues like:

- DoS attacks;
- discovery of cybercrime, for example loss of data or payment card information;
- malware outbreak;
- incident requiring notification of a regulator, for example ICO for loss of personal data;
- service outages;
- security incident at a third-party service provider upon whom the organisation depends.

The first priority is to ensure that all the people within the organisation know how to recognise an incident and know to whom they should report it. This can be done in a number of ways including awareness training, dedication of a section on the company intranet/portal and by carrying out exercises.

There are normally five phases in the management of an incident:

1. reporting;
2. investigation;
3. assessment;

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

4. corrective action;
5. review.

In order to ensure that enough information is captured, it is good practice to have a standard form to hand on which to record the information given by the person making the initial report. The form should be easy to find on the intranet and should prompt the user for the following information:

- who they are;
- where they are – geographic location and department;
- contact details – address, telephone (desk and mobile), email, IM;
- brief description of incident;
- whether there is any danger to life, health or company assets;
- other potential impact to business operations;
- description of anything they have done to date in response;
- time first noticed.

Any favourite search engine will help to find plenty of examples of reporting forms and sample incident response plans from which inspiration can be gained to create ones suitable for an organisation.

From the moment of the first report until the incident is closed, a log should be kept of information, decisions made and the consequences of any actions. These records will be invaluable later – both for internal use and also for possible use by external agencies including those for law enforcement. In the event that there are legal or regulatory consequences to the incident, these records may be required to be presented as evidence in a court of law.

Incident response teams/procedures

An incident response team (IRT) must be appointed up front and all members of that team should be properly trained, briefed and prepared in how to use the plan. The members need to come from a cross-section of the organisation to ensure that there is sufficient breadth of knowledge to deal effectively with the situation. They need to be senior and experienced enough to have the authority to make decisions on the spot. The IRT must also be empowered to call upon additional resources, internal and external, as they see fit to use in resolving the incident.

There needs to be a documented escalation process for the team to reach the most senior members of the organisation as and when necessary. The senior risk owner, who is normally a board member, will need to be briefed and ready to provide support and additional resources if required to help respond and recover. It is advisable to give each of the team a laptop with remote access to the organisation. It should have a full set of the incident response plan documentation and be suitably encrypted to protect the contents. Each member of the IRT should also have a company mobile phone so they can be contacted immediately and also reach out to each other when the IRT is activated.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

Ideally, one or more persons on the IRT should be designated as note-takers. Their job is not to be involved directly, but to observe and record all details of the incident in a logbook for reference later. It is a good job for someone who is learning about information assurance in general, because they get to see first-hand what does (and does not) work.

The procedures must be quite broad in their content and scope because it is very difficult to predict the nature of the next incident. Some idea of likely events can be gained from looking at the risk register and the output of the BIA, in order to identify high probability and high impact events. There are some events, though, perhaps terrorist activity or environmental damage such as flooding, that are not part of the normal threat profile but can happen. An incident may seem unlikely but in the last 20 years one of the authors has lost three IT systems to terrorist action and was called up as an expert witness after a law enforcement organisation had one of their data centres destroyed by the Buncefield storage depot explosion in 2005.

Need for links to corporate incident management systems

Large organisations often have mature processes in place to support incident response teams. There is often a centralised function with access to resources and expertise to help deal with the incident. The latest procedures and contact lists may well be publicised on the intranet or information portal. In a geographically dispersed organisation it may be that other offices will have plans to send in specialist staff to help with managing and recovering from an incident, to provide cover for the affected location, or to prepare to receive staff relocated from affected premises. Even if an organisation is not one of these, it is worth approaching a large organisation located nearby. In return for the offer of help (perhaps an office with phones and internet access) in the event of a major incident, their IRT may well be prepared to offer reciprocal facilities and advice and guidance based on their experience.

It is worthwhile getting to know these people because the better prepared an organisation is, the better it will be able to handle the incident – whatever it may be. It is also well worth reading advice freely available online, such as the 'Respond' and 'Recover' sections of the NIST Cybersecurity Framework. Partnerships with other organisations can also provide valuable intelligence on attacks and incidents that might give an early warning, allowing an organisation to prepare better.

Processes for involving law enforcement

There are times when it will be necessary to involve law enforcement or other similar organisations in the response to an incident. In some countries there are incidents that require mandatory reporting to law enforcement, and it is important to know who they are in your local jurisdiction and that it may vary if there are offices in more than one country. For example, it is mandatory in the UK to inform the police if there is a suspicion of terrorist activity, a danger to life is suspected or that child pornography has been viewed or processed through the IT systems of an organisation. UK legislation also requires the reporting of suspicious financial activity.

If there is any likelihood of criminal activity or other deliberate action, the appropriate authorities should be notified. It is important that the IRT and senior management have

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

a good understanding of the legal requirements for reporting certain events and how to capture information to a standard that allows for forensic admissibility. This can be complex and is another reason why prior planning and preparation is essential. One single mistake in the procedure can render everything inadmissible in a court of law. Expert advice and guidance are highly recommended. A good starting point in the UK is to read *Good Practice Guide for Digital Evidence* (V5) (2012) published by the National Police Chiefs' Council (NPCC) (formerly the Association of Chief Police Officers (ACPO)).

Another risk is that of attempted extortion and blackmail where an attacker conducts something like a DDoS or ransomware attack on an organisation. In this case, the National Crime Agency (NCA) is the appropriate body in the UK to contact. Activity of this sort, or malware (malicious software) discovered in UK government departments, should lead to a report being passed to the NCSC. In other countries there will be similar organisations and law enforcement agencies who will be the key point of contact for such incidents. Often these are known as the computer emergency response team (CERT).

One last possibility is that an organisation may be visited by law enforcement officers conducting an enquiry into activities of which management has no knowledge. They may have a warrant to search the premises and remove items, or they may simply be conducting enquiries. The modern UK police force is aware of commercial sensitivities and the nature of intellectual property. While the organisation is best advised to take appropriate legal advice from internal or external sources, an open and co-operative response is almost always the best policy. One example of this is that the organisation must ensure it is abiding by the requirements of the local data protection regulations (GDPR in Europe) before providing any information to a third party, even if they are a law enforcement body. It is normally necessary for a legally-issued warrant to be presented to enable the organisation to provide data without fear of later repercussions from the ICO or other regulatory body.

ACTIVITY 3.5

The last external audit of GANT identified that there was no process in place to deal with any assurance breaches. Ms Jackson has asked you to produce a simple process for managing information security incidents. How would you approach this and who would you involve?

LEGAL FRAMEWORK

This section covers the general principles of the law in relation to information assurance management. This will cover a broad spectrum from the assurance implications on compliance with legal requirements affecting business (e.g. international electronic commerce) to laws that directly affect the way information can be monitored and copied. It will also refer to certain pieces of legislation to explain concepts and highlight the legislative variances between separate countries.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

LEARNING OUTCOMES

The intention of this section is to provide you with basic knowledge of some of the general principles of law, legal jurisdiction and associated topics and how they affect information security management. Following study in this area, you should be able to explain and justify each of the following concepts.

Background

The UK's legal system has evolved over a long period of time. Within Britain, it can be traced back as far back as Roman and Anglo-Saxon times, and laws that were in place years ago can still exert an effect on the legislation of today. Legislation is continually evolving to adapt to the changing needs of modern-day life and reflects the cultural development and values of society. Understanding this can help to explain why there is variance in the legislation between different countries.

Countries that have some form of federal government will have multiple levels of law – such as in the USA, Australia, Canada or Switzerland, where there are local state laws that are ultimately subject to national or federal laws. Within the EU, there are European directives (agreements between the member states) that have been produced to harmonise pieces of legislation across member states. Each country has to incorporate the legislation into their own legal system, and this can result in subtle yet significant differences as each country interprets the directives in their own way.

The legal systems across the world do share many similarities and common legal concepts. However, as enterprises increasingly operate or perform transactions in more than one country, it is necessary to understand each particular legislation and how it can affect the enterprise's information as it crosses international boundaries. Organisations should always consult with a qualified lawyer to be sure what legislation is applicable to them.

The requirements from one legislative system may be inconsistent with another, making compliance with all of the relevant laws of multiple jurisdictions difficult. Understanding legislation can be complex, and pieces of the legislation can sometimes conflict with one another. The ISO/IEC 27000 series provides organisations with guidance regarding compliance with legal requirements and covers the following areas:

- intellectual property rights;
- protection of organisational records;
- data protection and privacy of personal information;
- prevention of misuse of information processing facilities;
- regulation of cryptographic controls.

Non-compliance with legislation could prove costly for an enterprise through incurred financial penalties, operating restrictions or, in extreme instances, custodial sentences

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

for senior executives. Therefore, it is essential that advice is taken from a trained legal specialist before making any important decisions that could put the organisation at risk.

Protection of personal data and restrictions on monitoring, surveillance, communications interception and trans-border data flows

Privacy laws exist to protect the rights of the individual. Most organisations hold and process information about people such as employee or customer information. Organisations need to be aware of the legal restrictions placed on them to protect this information and how it may be used and monitored. The latest EU regulation covering data protection is the GDPR, which came into effect in 2018. In the UK this was supported by a revised Data Protection Act that spelt out how the EU regulation would take effect in the UK and also in the event of the UK leaving the EU. Many countries have legislation to protect the individual and restrict and control the amount of information held and how it should be used and monitored, but the GDPR was arguably the first comprehensive legislation that now affects all the personally identifiable information (PII) about any citizen of the EU regardless of where the information is held.

Although all the various forms of the legislation do share some common principles, there are significant differences in the legislative approaches, and this can cause difficulties when working across different legal jurisdictions. The EU has a legal framework via the GDPR to protect all types of personal information, whereas the USA protects personal information via a number of federal statutes. These tend to target specific areas such as protection of customer information by financial institutions (via the Gramm-Leach-Bliley Act) or preserving privacy of medical information (Health Insurance Portability and Accountability Act (HIPAA)).

The scope of legislation can also vary from country to country. For example, the Canadian Personal Information Protection and Electronic Documentation Act applies to the records of people for up to 20 years after their death, whereas in the EU any protection ceases at the time of death.

The GDPR within the EU protects the individual by ensuring that information is collected and processed lawfully, is accurate and is appropriate. Individuals have the right to have access to information held about them, know who can access it and have any inaccuracies amended. The Act also has provision to ensure that information is only collected (in general) with the explicit approval of the individual and that it is handled and processed in a secure manner, while placing controls on transferring it out of the EU to countries that have less stringent privacy controls. It also covers both electronic and paper-based records. The main points to remember when handling personal information are:

- Personal information must be surrounded by proper robust assurance controls and working practices to protect the data from unlawful processing, accidental loss, corruption or destruction and unauthorised disclosure.
- Processes should be implemented to ensure that information is entered into computer systems correctly and that staff understand that no personal information should be disclosed to any third party without the appropriate written authority being in place.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

- Paper records should be kept locked away and computer screens should not be left displaying personal information or able to be overlooked. Information no longer required should be destroyed by shredding or other secure forms of destruction.

Privacy laws often place restrictions on transferring information between countries. For example, the EU's GDPR states that personal information must not be transferred to countries that do not have such similarly strict rules. Certain countries, such as Argentina, Canada, New Zealand and Switzerland have already (at the time of writing) shown that they operate a data protection model which is comparable to the EU GDPR model, and there are no restrictions with these countries. Doubtless, more countries will follow suit over time. For other countries, safeguards need to be considered to enable trans-border data flows to take place legally.

The European Commission and the United States Department of Commerce developed the Privacy Shield framework to enable American organisations to be compliant with the EU's GDPR privacy legislation. American companies that are likely to exchange personal information with EU-based organisations can amend their assurance arrangements so they are compliant with the Privacy Shield framework. For other countries, such as for transfers to the Indian subcontinent, it may be possible to make the data transfer if a number of prior safeguards are put into place. These safeguards would be undertaken via approved contractual terms that are acceptable to the legal body responsible for protecting personal information.

In the UK, the individual has a right to a level of privacy, protected by legislation, that restricts how their personal information can be monitored or intercepted. This legislation may often predate the computerisation of data storage such as the UK's Public Records Acts of 1957 and 1967. Any monitoring and collection techniques employed by an enterprise must comply with these laws. If the monitoring controls are to be used across more than one legal jurisdiction, then there may be differences in the rights of the individuals being monitored. Within the UK, the Regulation of Investigatory Powers Act 2000 (RIPA) was enacted to restrict covert monitoring of an individual's information. It was introduced to take account of new developments in communications technology, the Human Rights Act and the Telecommunications Directive.

Employment issues and employee rights

Depending on the legal jurisdiction, employees have certain rights when using the enterprise's information systems, such as the right to privacy and the right to know what information is held about them by the enterprise. In the UK, for example, under the GDPR, individuals can request a copy of any information that any organisation may hold on them. This is called a Subject Access Request.

Rights may also extend to monitoring controls. Within the EU, employees have the right to know the type and scale of monitoring that is being carried out by the enterprise and why it is being done. For instance, an employer might consider it necessary to protect the enterprise from offensive or pornographic material, or perhaps they need to understand the volume of email traffic being propagated for performance purposes. The enterprise must communicate this information to employees. The easiest way to do this is to include a statement about the extent of monitoring in the enterprise's information assurance policies or employment contracts. If this is not done, it may be necessary

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

to gain specific consent from individuals to allow their information to be collected and/or monitored. An assessment of the monitoring strategy should be carried out to demonstrate that the monitoring techniques that are being used are justified, not excessive and meet legal requirements.

If monitoring tools detect information that is clearly personal, then care must be taken not to violate the individual's right to privacy. For example, a clearly personal email should not be opened by the employer or an individual's email account should not be accessed unless agreed with them beforehand. These can cause operating issues. For instance, a colleague may need to quickly obtain important company information previously sent to an individual while that person is away on holiday. Employees should be asked to remove any of their personal information from IT resources when they leave the enterprise to avoid it being viewed by others.

Monitoring tools should not be used to target any particular individual and covert monitoring is rarely justified; exceptions might include situations where there are clear grounds that criminal activity or malpractice is taking or has taken place. Internal investigations may lead to an employment tribunal or a court case. It is important that any information that is collected meets the legal requirements, which might include, for example, the UK's Freedom of Information Act or the equivalent in other countries.

Common concepts of computer misuse

Much of the legislation that currently applies to the misuse of computers has not been written specifically to address computer crime. It can be said that crime is crime and criminals simply use whatever means are available to carry it out. Blackmail, fraud, deception, theft and so on have always existed, but developments in technology have enabled criminals now to exploit computing devices in their activities. Similarly, privacy rights can be abused via electronic eavesdropping, hacking or cyber stalking, rather than by an actual physical presence. Therefore, existing laws that predate computers are often used to prosecute computer misuse.

Legislation has been produced to specifically target crimes committed using computers. The USA introduced the Computer Fraud and Abuse Act in 1984 and this legislation has since undergone several amendments. The UK was the first European country to enact a law that specifically addressed computer crime, and this legislation formed the basis of the EU Directive on Computer Misuse. The Computer Misuse Act 1990 introduced three new offences: unauthorised access to a computer; unauthorised access with the intent to commit or facilitate further offences; and the unauthorised modification of computer material. The misuse of computers can include:

- illegal access (hacking) to computer systems;
- illegal interception of information;
- interference with information and systems;
- computer-related fraud and forgery;
- commercial infringement of copyrights;
- download of illegal material such as child pornography;
- trafficking in passwords, digital signatures and encryption keys.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

The motives for the misuse of computers can vary. Fraudsters may misuse a computer for financial gain; hackers may try to gain access to a system for the intellectual challenge; a disgruntled employee may sabotage a computer system as an act of revenge.

Computer fraud is the term used to describe stealing money or goods by using or involving a computer. There are various ways that this can be achieved, either by entering incorrect information or by altering the information already held on a computer. It can also be carried out by creating or altering computer code. Misuse of computers in this manner is a major problem as organised criminals continually find new opportunities to use computers to commit fraud. Business fraud, as this is often labelled, is now one of the most common ways of criminals making money from business. In a Bromium Inc. sponsored report researched and written by Dr Mike McGuire in April 2018, titled *Into The Web of Profit*,[2] Dr McGuire estimated that the theft of intellectual property (IP) and trade secrets alone generates $500 billion each year for the criminals.

The increasing use of the internet to trade and shop enables criminals to commit fraud and steal the identities of others to commit fraud. Phishing is the term used where criminals entice individuals to disclose their financial details, for example by sending an email to an individual that purports to have been sent by their bank or perhaps by a senior member of staff in their employer's company. This constitutes obtaining information by deception.

Hacking (despite its benign origins as a term for a general interest in discovering how computers work) is the term given to accessing a computer system without the express or implied permission of the owner of that system. A hacker is the name given to the person that carries out this activity. Hackers often modify information or software programs – which can subsequently cause considerable havoc. Website defacement is an example of where a hacker changes the information displayed on a web page. Sometimes, hackers will change information held within a database. Hackers often gain unauthorised access to a computer system simply for the thrill of being able to circumvent assurance controls and then share their conquests with other like-minded individuals. However, hacking is now increasingly being used as a tactic by criminals to carry out crimes such as fraud or blackmail. Notably one of the most common targets for this type of activity are the systems running out-of-date software or where the latest patches to address known vulnerabilities have not been implemented.

Malicious code (or malware) is the term used to describe programs that have been written to cause security breaches or damage to computer systems by installing unwanted and unauthorised code onto them. Malicious code can cause a number of undesirable impacts including the deletion or corruption of information, the capture of information or the hijacking of computer resources to launch further attacks onto other computers in DDoS attacks. Malicious code comes in a variety of forms such as viruses, Trojan horses and backdoors. Malicious code is being increasingly used by criminals, especially to capture financial information held on a computer that can be used for fraudulent purposes. Ransomware is an example of malware that infects the target computer by encrypting the owner's personal files. The victim is then contacted

2 https://www.bromium.com/resource/into-the-web-of-profit/

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

and offered the key to decrypt the files in exchange for cash or information. Dr McGuire estimates that ransomware adds a further $1 billion annually to the criminals' gains.

The download of illegal material onto a computer is another form of computer misuse. Many countries have in place legislation that prohibits the download of child pornography and of the 'sexual grooming' of children using the internet. In many countries there is a legal obligation for enterprises (and individuals) to report the discovery of this type of activity to the law enforcement agencies. It is very likely that legislation such as the Obscene Publications Act in the UK would be used to prosecute cases of child pornography, as the penalties are more severe than in computer misuse legislation.

Computers can be misused by a person to harass and stalk another individual (cyber stalking), for instance by sending threatening emails that cause distress. It is essential to ensure that policies are in place to provide clear guidance to all computer users as to what constitutes computer misuse. Cyber stalking of this nature is now recognised in the UK under the Public Order Act, the Malicious Communications Act and the Protection from Harassment Act.

The illegal or unauthorised use of software such as programs, computer games or electronically stored music is known as piracy and is another example of computer misuse. Only legitimate software and material used in line with licence agreements should be installed on an organisation's systems and guidance to computer users that the use of unlicensed material is not allowed should be provided.

Requirements for records retention

Certain documents or records need to be retained by an organisation for legal or regulatory purposes for a period of time. These can include company board minutes, financial reports and accounts or technical specifications. The duration for which documents need to be retained varies by the document type and the legislation of the country in which it is being used. In multinational organisations, records may be passed over to other countries within the same enterprise – meaning that the same data are then subject to different legislation requirements, which might even conflict with one another.

Although most retention requirements state a minimum length of time for keeping data, some legislation conversely states when a record must be destroyed. These usually relate to personal privacy, such as the GDPR (EU) or the Fair and Accurate Credit Transaction Act 2003 (USA).

An organisation may be asked to produce these records (or proof of destruction) either by a government agency or by an opposing party in a legal dispute. Failure to comply with this could result in a legal judgement against the organisation, heavy fines, and closure of business or adverse publicity.

To help in compliance with legislation, it is necessary to have in place a record retention policy and schedule. This should be communicated to staff so that they are aware of their responsibilities. In the case of international organisations, more than one schedule will need to be kept to deal with variances in requirements. A document that needs to be retained should be stored in a format that can ensure its protection (for example on

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

a secure central repository rather than in a personal file so that it is not deleted or lost inadvertently). For larger enterprises there are document management solutions on the market to do this.

There are a number of externally produced standards available to help enterprises understand how best to cope with legal requirements, such as ISO 15489-1:2016 – Record Management Standards produced by the International Organization for Standardization, or standards produced by the American National Standards Institute (ANSI).

Intellectual property rights, for example copyright, including its general application to software and databases

Individuals and enterprises invest a lot of time, money and effort in creating original works, products, methodologies and ideas. They can be significantly out of pocket if they are unable to realise the benefit of their investment because other parties have used their ideas without compensating them. Intellectual property rights (IPR) is the term given to the legal rights that protect creative works, and most countries have legislation in place to protect such intellectual property.

Copyright law was initially designed to protect original artistic works such as pieces of music, but its use can also be applied to software programs, computer games, documents, books, photographs, video files or other types of work made using a computer or generated by a computer. Copyright is automatically associated with the piece of work deemed as original upon its publication. It usually remains in place for a fixed duration, such as 50 years in the case of music. Copyright gives the creator exclusive rights over certain aspects of the work such as copying, issuing, performing or adapting it. Abuse of these rights by someone else is called infringement. Piracy is the term commonly used to describe the unauthorised use of computer software and is a breach of copyright law. Where software has been developed by an enterprise, the copyright is normally owned by the enterprise rather than the individual(s) involved, unless a special provision has been agreed beforehand.

Copyright legislation is prevalent in most developed countries but there are some countries that take copyright less seriously, such as in Asia and the Far East. There have been a number of initiatives to harmonise copyright protection internationally, such as the General Agreement on Tariffs and Trades, Trade Related Aspects of Intellectual Property Rights 1993 (GATT TRIPS). Within the EU there is a directive to harmonise certain aspects of copyright and associated rights in relation to information systems.

In addition to copyright there are other pieces of legislation that aim to protect intellectual property, and it is useful to have an awareness of some of them. The Common Law of Breach of Confidence (often described as a tort) aims to protect secrets – personal, commercial or governmental. These can only be applied for as long as the data are not in the public domain and covers breaches of confidence made between two or more parties. Trademarks, such as Microsoft® or Apple®, are there to protect brand strength by demonstrating their uniqueness in terms of quality, reputation, reliability, ubiquity, originality, value for money or whatever the brand strives to promote.

'Passing off' is the term used when an object is trying to seem the same as something else in order to cash in on the originator's reputation or ideas. This legislation is intended

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

to protect the public from deception and to stop misrepresentation. An example of infringement that could apply to information assurance is when someone has set up an internet domain name that uses a very similar name to another, better-known site. The 'impostor' site is branded in much the same way as the original so that people who have mistyped the address believe they have gone to the intended site. This is a typical method of perpetrating banking fraud. Dr McGuire estimates that the trade in illicit and illegal online markets generates $860 billion each year for the criminals.

Patents are used to protect the intellectual property invested in the development of new products or in the creation of inventions, and, like copyright, they are in place to prevent other people from copying or manufacturing the product or invention so that the creator is able to realise their investment (in both time and money) in creating their original work. Increasingly, patents are applied to software processes and such things as 'gestures', for example, on tablet computers. Within information technology, patents tend to be used to protect physical devices such as a new type of computing device. Patents are of a fixed duration, but can often be renewed by the owner. Patents tend to apply only to the particular country in which the application has been made. Extending patents to cover many countries can be expensive as multiple applications may have to be submitted, and so expert advice should be sought. However, there is provision within the EU to protect a patent in 30 countries in a single application, using the European Patent Convention (EPC).

Contractual safeguards, common security requirements in outsourcing contracts, third-party connections, information exchange and so on

When developing contracts with third parties it is important to ensure that controls are put in place to protect the information assets of the enterprise to an acceptable level. In effect, it is necessary to ensure that a third party would take the same level of care in protecting an organisation's information as the organisation would internally. The types of safeguards required will vary depending on the type of service being provided and the sensitivity of the enterprise data.

Contract conditions should include clauses to ensure that proper assurance controls are in place. Security conditions are often handled via a security schedule within the contract. The type of clauses needed to provide adequate protection might include clauses to:

- carry out regular assurance reviews and health checks;
- apply security patches in a timely manner;
- protect information against malicious code;
- provide business continuity arrangements that meet agreed service levels;
- vet new staff to an appropriate level;
- enforce discipline against any security breaches;
- manage security incidents (including reporting any incidents to the parent organisation);
- protect against disclosure of sensitive information;

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

- allow the enterprise the right to audit and monitor the services being provided;
- prevent further subcontracting without written authorisation.

Many organisations use cloud computing services. It is essential that the organisation understands the services that are being bought and contractually protects its information adequately. This is discussed in more detail in Chapter 6.

Collection of admissible evidence

There are a number of rules and processes that need to be followed when collecting evidence so that it can meet certain criteria when used in a court of law (described as admissible evidence). If legal guidelines are not followed, the evidence may be excluded as being inadmissible. This could result in a court case being lost, adverse publicity, embarrassment and financial penalties to the prosecuting party.

This generally means being able to demonstrate that the evidence is authentic, has not been tampered with in any way and has been gathered in an acceptable manner that meets legislative requirements, which includes being able to retain and document the state and integrity of items at the crime scene. Most countries have produced legal requirements that specify how evidence should be handled. Examples are the Federal Rules of Evidence (in the USA), the Police and Criminal Evidence Act and the Civil Evidence Act (in the UK). The appropriate guidelines should be followed when collecting evidence.

Developing a procedure for dealing with investigations and gathering evidence will help to avoid mistakes when working under pressure. Only trained personnel should carry out the securing of evidence. Some organisations, such as banks, may have an in-house facility for carrying out investigations as they may need to do this regularly. In other organisations, where investigations are rare, it may be better to call in an external specialist organisation to manage the investigation and collect the evidence.

Each person that has handled any evidence may need to testify in court that the evidence is in the same state as when it was processed during the investigation. Therefore, keeping the number of people involved in the investigation to a minimum helps to simplify the presentation of evidence and preserve confidentiality. Evidence needs to be presented in a form that is understandable to the judge, jury or adjudicator.

Evidence can be excluded because it was gathered without the correct authorisation or in a manner that contravenes guidelines. Sometimes a warrant may be required to seize evidence, although this is not necessary if the evidence is in plain view, for example, or consent has been given by the individual.

Collection of digital evidence can be complex and can come in a variety of forms, such as audit trails, application logs, firewall logs and closed-circuit television (CCTV) footage. Some of the information may be deleted, incomplete or partially overwritten. It is more difficult to isolate and preserve evidence from a communications network as it is in a state of constant change and the sources of evidence may reside in different locations. As mentioned previously, The *Good Practice Guide for Digital Evidence* (V5) published by NPCC (previously ACPO) in the UK, provides detailed advice on recovery of computer-based evidence. The guide states four principles when handling digital evidence:

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

- No action taken by the police or their agents should change data held on a computer or other media that may subsequently be relied on in court.
- In exceptional circumstances when a person finds it necessary to access original data held on a target computer, that person must be competent to do so and to give evidence explaining the relevance and the implications of their actions.
- An audit trail or other record of all processes applied to the computer-based evidence should be created and preserved. An independent third party should be able to examine those procedures and achieve the same results.
- The officer in charge of the case is responsible for ensuring that the law and these principles are adhered to. This applies to the possession of and access to information contained in a computer. They must be satisfied that anyone accessing the computer, or any use of a copying device, complies with these principles.

Use is often made of organisations that specialise in recovering and securing lost data from computer disk drives.

Securing digital signatures

Traditionally, a handwritten signature on an original document proves who signed it and any alterations can be detected. In the electronic world the original is indistinguishable from a copy and therefore there is potential for fraud. Digital signatures are a form of electronic signature that addresses this problem. A digital signature electronically binds the sender of a message to the contents of the actual message to prove that it is genuine. It also proves when it was sent, to whom it was sent, that it has not been tampered with, that it has been kept confidential and that neither party can deny its transmission. Enterprises are increasingly using digital signatures to conduct their business, and legislation has been developed to facilitate and control their use. However, what is acceptable varies across legal jurisdictions, so it is important that legal advice is obtained before adopting the use of digital signatures.

Within the EU, the legal regulation Electronic Identification, Authentication and Trust Services (eIDAS) came into force on 17 September 2014 and states that electronic signatures will not be denied legal effect or admissibility simply on the grounds that they are in electronic form. Electronic signatures will be treated as handwritten signatures if they are backed by qualified certificates, which are provided by a certification service provider and created by a secure signature creation device. Electronic signatures are admissible as evidence in legal proceedings both in relation to the authenticity of the transmission and as to the integrity of the contents of that communication. Applications supporting digital signatures are now available on smartphones and tablet computers as well as desktop and laptop computers.

There is much emphasis on the certification authority (CA) to be deemed trustworthy. CAs generally have their signatures verified by other CAs to build a greater degree of trust. CAs may be liable for any compromise to the integrity of digitally signed documents authorised by them, so, to limit their liability, many certification authorities stipulate a financial cap on transactions. There have been malicious attacks on digital certification companies, though, and this has led to some significant improvements in recent years.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

Some legal jurisdictions control the extent to which foreign certificate authorities can issue certificates that meet local laws. In the EU, there has to be a recognised arrangement between the EU and the country that has issued the certificate.

Restrictions on purchase, use and movement of cryptography technology

Cryptography is a powerful tool for protecting privacy that can be used by businesses, governments, criminals and individuals to protect confidential information. Governments argue that it is in the national interest for them to control cryptographic activity in order to protect the individual and to prevent and track criminal or terrorist activity. As such, there are numerous controls in place over its use. Cryptography legislation varies greatly from country to country. In some countries the controls are quite draconian, especially where repressive political regimes are in government. It is important that organisations which operate internationally understand the local operating restrictions as penalties can be extremely harsh (i.e. for treason) and the death penalty is included in some statutes.

In China, foreign organisations and individuals have to gain permission to use cryptography under the China State Council directive 273 of the Regulation of Commercial Encryption Code. In Pakistan, all encryption hardware and software has to be inspected and approved by the Pakistan Telecom Authority. Even within the EU, there is variance on acceptable use of cryptography. France, for example, has a number of very specific requirements as to how cryptography can be used that are in addition to the EU directives.

The export of cryptographic controls is controlled in many countries by the Wassenaar Arrangement (WA) 1996. The purpose of this agreement was to ensure that transfers of conventional firearms and dual-use goods and technologies between countries were carried out responsibly and did not further the development of hostile regimes. There are, at the time of writing, 42 participating countries and, although export controls are implemented by each individual WA participating state, the scope of export controls is determined by Wassenaar directives.

Cryptographic controls should be used in compliance with all relevant agreements, laws and regulations. Local legislation may disallow or restrict the use of strong cryptography. It may restrict its sale and movement to another country or put in place regulatory controls and registration requirements for its use. You should seek legal advice to ensure compliance with any national laws and regulations and when transferring encrypted information or tools from one legal jurisdiction to another.

The ISO/IEC 27000 series advises that the following factors should be considered:

- restrictions on import and export of computer hardware and software for performing cryptographic functions;
- restrictions on import and export of computer hardware and software that is designed to have cryptographic functions added to it;
- restrictions on the use of encryption;

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

- mandatory or discretionary methods of access by the countries' authorities to information encrypted by computer hardware and software to provide confidentiality of content.

For organisations that are subject to regulatory control, the associated regulatory body may define additional constraints on how cryptography should be used; for example, the finance industry may specify use of particular security standards. These factors also need to be considered when applying cryptographic controls.

You should be aware that legislation is in a continual state of change and improvement, and should verify for yourself that you are using the latest legal instruments.

ACTIVITY 3.6

Following the information leak, Ms Jackson is worried that GANT's controls for protecting personal information may be weak. She has asked you to carry out a review of the privacy legislation affecting GANT to ensure that the organisation is compliant. What would be the main areas that you would look at?

SECURITY STANDARDS AND PROCEDURES

Standards affect many aspects of our daily lives and they have been developed to ensure that products and services are safe, reliable and efficient. They also provide for interchange ability (interoperability between products and systems). Today, there are recognised standards in place for almost all aspects of commerce, industry or government, and information assurance is no exception to this. Standards are produced by recognised standards bodies and they enable organisations to demonstrate a requisite level of technical, operational or administrative competency. There are many standards and technical regulations in existence and many organisations worldwide producing them. This section will look at how externally produced standards affect information assurance management within the enterprise.

LEARNING OUTCOMES

The intention of this section is to provide you with the basic knowledge of some of the main externally produced standards that apply to information assurance management. Following study in this area, you should be able to explain and justify each of the following concepts.

National and international standards

In the area of information assurance there are many standards that apply. These typically define a set of requirements for products, processes or procedures and they are produced by organisations known as standards bodies. They collaborate with

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

industry experts in different areas, whether representing vendors, scientific research agencies or government departments, to produce good practices that can be applied by others. The jurisdiction of a standards body may extend to a specific industry sector, a particular country or internationally. The standards that will apply to an enterprise will vary depending on a number of factors, which may include the actual country in which the enterprise is based, whether it works internationally, the industry sector in which it operates, or perhaps engagement in government contracts. Most standards are produced by non-profit making organisations and are funded by the various parties that have a vested interest in their existence. Typically, they do not actually regulate the adoption of their standards, although some do provide certification or accreditation to organisations to allow them to demonstrate compliance to the set standards.

Although not mandatory, failure to implement or comply with accepted standards may have a significant adverse effect on an organisation. For instance, if a product or service is not certified as being compatible with other vendors' offerings, then this may dissuade potential customers from placing orders. Alternatively, the organisation may not be able to demonstrate a sufficient level of competency in managing particular processes. Therefore, it is important to understand the standards that can or need to be applied within the enterprise. The remainder of this section will look at some of the common standards related to information assurance as well as the standard-producing organisations themselves.

The International Organization for Standardization (ISO) is the world's largest developer of standards and has published over 22,500 international standards since it was established in 1947. The organisation was founded to facilitate the international co-ordination and unification of industrial standards. ISO standards are mainly technical and cover a wide number of sectors, including agriculture, construction, engineering and information technology. ISO standards are developed collaboratively by committees from more than 160 participating countries. Each standard is reviewed at least every five years to ensure that it remains current and those that are no longer relevant can be withdrawn. Editions of these standards are formally published by the ISO and can be purchased either from ISO directly, or through national standards agencies such as BSI in the UK.

The ISO works in collaboration with two other international standards organisations, the International Electrotechnical Commission (IEC) and the International Telecommunication Union (ITU), to form the World Standards Cooperation. These organisations have been extremely influential in producing standards that affect the information technology industry. The naming convention for standards approved jointly by IEC and ISO is ISO/IEC and there are a number of joint standards that directly affect information assurance management. The most significant is the ISO/IEC 27000 series, which is the current set of standards for information security management. There are, however, many others that cover explicit technologies, techniques or architectures used within IT.

The two main standards in this series are ISO/IEC 27001 and ISO/IEC 27002. Others have been developed within the series to cover specific topic areas or industry sectors. For example, the series includes a standard on risk management (ISO/IEC 27005), network security (ISO/IEC 27033), guidelines for managing information security in the health sector (ISO/IEC 27799) and using cloud resources (ISO/IEC 27017).

ISO/IEC 27001 specifies the information security management system requirements standard. Organisations can be formally certified against it and this will be covered

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

in more detail later in this chapter. ISO/IEC 27002 provides a code of practice for information security management. It is probably the most influential standard for information assurance management. It describes a high-level set of controls to protect the confidentiality, integrity and availability of an organisation's information assets, and looks at the various aspects of assurance such as security policy, information assurance organisation, asset management, human resources assurance and compliance. ISO/IEC 27002 is a generic advisory document rather than a formal specification like ISO/IEC 27001. In order to use the standard, the organisation will need to assess the risks of their enterprise and apply the recommended control measures from the standard that are applicable to mitigate these risks. ISO/IEC 27007:2017 provides guidelines for auditing information security management systems, helping auditors to assess the compliance with ISO/IEC 27001.

Other international organisations produce standards on security management; for example, the ISF's *Standard of Good Practice* for information assurance, which is reviewed by them every year. This standard focuses on how information assurance can support an organisation's business processes and provides guidance on implementing appropriate protection. It focuses on security governance, security requirements, control framework and security monitoring and improvement. The ISF membership (who are in the main corporate organisations) fund the forum via an annual subscription, and then collaborate with them in developments for best practices in IT security and information risk management. However, the *Standard of Good Practice* is available to other organisations or individuals.

There are many other standards not produced exclusively for information assurance that do affect information assurance management. These cover other related business functions or processes such as retention of records (ISO/IEC 15489), the implementation of business continuity (ISO/IEC 22301:2019 and PAS 77), project development (COBIT), the management of information technology services (ISO/IEC 2000 ITIL) and quality assurance (ISO/IEC 9001). If these standards have been implemented within an organisation, it is necessary to ensure that information assurance management controls are compatible with them and support their requirements. For example, ISO/IEC 20000-1:2018 Information technology – Service management includes requirements for operational security.

It is necessary to be familiar with the standards that apply to the country and industry sector in which the organisation operates. There are a wide range of standards to which the financial and manufacturing industries need to adhere, and an inability to meet these requirements could, for instance, prevent an organisation from actively trading in the financial services market.

Certification of information security management systems to appropriate standards

Gaining information assurance certification is a means of demonstrating that an organisation takes information assurance seriously and that good assurance processes and controls have been implemented. An increasing number of organisations now look for certification in their trading partners and, for some, certification can be a prerequisite for doing business. Certifications can apply enterprise-wide or to a specific

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

set of processes within the organisation. Certification usually involves the enterprise undergoing an external audit by an accredited third party.



The ISO runs a number of certification schemes against its standards, including ISO/IEC 27001, which enables an organisation to have its information assurance governance and management processes certified against ISO/IEC 27001. To gain accreditation, the organisation's ISMS has to undergo an external audit carried out by an accredited third-party organisation. The auditors use standard processes to check the organisation's ISMS policies, standards and procedures against the ISO/IEC 27001 requirement and then look for evidence that they are being used within the organisation. The findings from the audit are reported back to the organisation and certification will be granted if successful. After the initial certification, periodic follow-ups (reassessments) will take place to ensure that the standards are still being met. There is also an ISO standard (ISO/IEC 27006) that is used to guide the accredited certification bodies on the formal processes for certifying or registering other organisations' information assurance management systems.

In the UK, industries such as financial services require that certification to certain standards are in place, and serious instances of non-compliance can lead to sanctions from the FCA, such as heavy fines or withdrawal of their registration. An example of an applicable standard is the PCI DSS. It was originally implemented in the USA, but has now been extended to include many other countries. It was introduced to reduce credit card compromise and to deal with increasing cases of fraud. It specifies the protection measures that organisations processing card-payment information must put into place. Failure to comply may result in an organisation receiving substantial fines or steps being taken to prohibit the organisation using cards as a payment method. This could seriously jeopardise the organisation. PCI merchants, retailers and service providers must store credit card account data securely as specified by the standard and demonstrate compliance to their acquiring (merchant) bank. All acquiring banks need to have certified proof of PCI compliance from their merchants or they will be liable to fines themselves from the FCA.

Product certification to recognised standards

Many products require independent testing and certification before they can be launched onto the market to ensure that they conform to safety requirements, technical specifications or other compliance regulations. It is useful to have an independent third party to verify that a new product does meet expectations and that it can be trusted. This particularly applies to security products, as it is often difficult for the consumer to be able to test the security of the product for themselves. Certificates provide customers with the assurance that the security features do offer the level of protection that is claimed by the vendor. It is helpful to know that a standards-based approach has been used to do this evaluation, as this will aid understanding as to how rigorous it has been. Test results produced in a standardised format will enable straightforward comparison with other competing products.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

Security testing, evaluation and certification have mainly been carried out by either government agencies or organisations serving the defence market. Different countries have developed their own evaluation and certification systems using a variety of classification models and approaches. This has often made life complex when dealing with other internationally recognised certification schemes. It has meant that products have to be recertified each time for use in different countries or industry sectors, which has exacerbated an already time-consuming and expensive process.

Over recent years the numerous certification schemes have been streamlined. In the 1990s the EU harmonised the various schemes of its member states into the Information Technology Security Evaluation Criteria (ITSEC). More recently this scheme was itself harmonised with other models, such as the Canadian Trusted Computer Product Evaluation Criteria (CTCPEC) and the US Federal Trusted Computer System Evaluation Criteria (TCSEC – often referred to as the Orange book) to form the Common Criteria for Information Technology Security Evaluation Criteria (CC ITSEC). This evaluation system has become the internationally accepted approach for security certification, replacing national and regional systems. In 1999 the ISO incorporated its evaluation criteria into a standard that was revised in 2009 to the current ISO/IEC 15408-1:2009 Information technology – Security techniques – Evaluation criteria for IT security – Part 1: Introduction and general model. This standard, together with parts 2 and 3, is now the most widely used certification model and, at the time of writing, it is currently under review for a second time before being reissued.

The ISO/IEC 15408 standard specifies a number of functionality and assurance classes that can be tested. The standard has seven levels of assurance to describe the level of rigour used to carry out the testing, from the entry level of Evaluation Assurance Level (EAL) 1, which tests claimed functionality to the highest classification, to EAL 7, which provides a formally verified design that has been subjected to rigorous testing. The higher the classification, the more complex and rigorous the testing is. Gaining classifications EAL 5–7 is generally less common for commercial organisations, as testing requires very specialist security engineering techniques and is complex. These higher classifications tend to be used by military and government organisations.

The developer of the product or system has to define what is being submitted for evaluation, known as the target of evaluation (ToE), and specify the assurance level for which they are aiming. Certification is carried out by an approved testing agency. Within the UK, security certification is managed by the NCSC, part of the Government Communications Headquarters (GCHQ) at Cheltenham. This is the UK Government's national technical authority for information assurance.

An NCSC Tailored Assurance Service (CTAS) evaluation provides a view of assurance on the IT security attributes of a system, product or service and will be carried out by a company with an NCSC-approved test laboratory with CTAS capability. The scope of the evaluation is specified in a security target and the range of evaluation activities is detailed in an evaluation work programme. The accreditor and NCSC, with other key stakeholders, will agree the scope and technical approach of the evaluation and will review the CTAS activities and results documented in an evaluation report. At the end of the evaluation, NCSC will issue a CTAS assessment statement on the results of the evaluation, making recommendations on the significance of any issues that are discovered. CTAS maintenance provides continued assurance to evaluated

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

configurations by understanding and assessing changes in an efficient and tailored manner.

To enable the international use of existing certificates, agreements have been put into place to enable security certificates to be recognised by other countries. For example, the Common Criteria Recognition Arrangement (CCRA) enables Common Criteria (CC) certificates up to EAL 4 to be recognised within all participating countries.

NCSC manage a number of certification schemes, including the Independent Evaluation for Assured Services (CAS), Commercial Product Assurance (CPA) and Certified Assisted Products (CAPS) for any commercial product and its developer. They also manage the Cyber Essentials scheme for companies that helps small and medium-sized enterprises to ensure the very basic cyber security controls are in place and effective.

Awareness of the production of key technical standards

There are several technical standards applicable to information assurance management. This section will examine some of the more well-known technical standard producing bodies.

The Internet Engineering Task Force (IETF) is a large, open international community that develops and promotes standards for the internet. Its governing body meets two or three times a year. Standards are developed by working groups of interested parties, such as network designers, operators, vendors and researchers, that each focus on a particular topic. The standards generated are known as Request for Comments (RFCs), and upon production are subsequently issued to the IETF community as draft RFCs for comment and review. Once an RFC has been issued it is not withdrawn, although it may in time be superseded by further RFCs. This, in many ways, can show the development of standards. The published RFC documents have a status of either a proposed standard or an informational statement.

Federal Information Processing Standards Publications (FIPS PUBS) are standards and guidelines developed and issued by the NIST for federal government computer systems within the USA. Where possible, the US federal government uses existing (internationally recognised) published industry standards, but should none be suitable it will ask NIST to help develop them. NIST collaborates with national and international standards committees such as IETF and other interested parties (such as vendors and industry bodies) to produce FIPS PUBS.

Within Europe, the European Telecommunications Standards Institute (ETSI), based in France, has official responsibility for standardisation of information and communications technology (ICT). It is recognised by the European Commission and the European Free Trade Association (EFTA) secretariat. Its main purpose is to provide technical specifications (or standards) that may be used in European directives and regulations or by manufacturers to show that their products are compliant with these directives and regulations. Products demonstrate conformance by attaching the 'CE' mark on their goods. ETSI members represent areas that have a vested interest in the process and include manufacturers, network operators, administrations, service providers, research bodies and users. They come from a wide selection of countries both inside and outside Europe. The members determine the Institute's work programme, allocate resources

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

and approve its deliverables. Documents can be downloaded from the ETSI website via their documentation service (EDS).

The European Union Agency for Network and Information Security (ENISA) also provides guidance and advice, based sometimes on its own scientific research work. Most recently at the time of writing, it has been looking at the human aspects of information security and considering the psychological, societal, ethnography, anthropology, human biology, behavioural economics and any other subject that takes humans as its main focal point.

SAMPLE QUESTIONS

1. **Which of the following activities should *NOT* be handled by the information assurance function?**
   a. Monitoring the effectiveness of the enterprise's assurance arrangements.
   b. Providing advice on information assurance.
   c. Effectively delivering a secure environment across the enterprise.
   d. Reporting on the effectiveness of the enterprise's assurance arrangements to senior management.

2. **Where should the information assurance function be placed within the enterprise so that it can facilitate full management co-ordination of assurance across the enterprise?**
   a. Within the compliance function.
   b. At board level.
   c. It will depend on the structure of the enterprise.
   d. Within the IT group.

3. **What is the main role of the board director with responsibility for information assurance?**
   a. To ensure that appropriate security controls are implemented across the enterprise.
   b. To have a detailed understanding of the threats facing the enterprise.
   c. To implement information assurance solutions across the enterprise.
   d. To provide day-to-day management of the information assurance function.

4. **Clearly defined responsibilities for information assurance should include which of the following?**
   a. Operating procedures and reporting requirements.
   b. The scope of the responsibilities and level of authority granted.
   c. Disciplinary procedure.
   d. None of these three.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

5. **Which would be the best way to hear about and plan for any regulatory changes to your industry that may affect information assurance?**
   a. Permanently employing consultants.
   b. Scanning bulletin boards and websites for snippets of information.
   c. Waiting until the changes are announced in the press.
   d. Maintaining a relationship with regulatory bodies for the industry.

6. **Which of the following groups of people should have access to the high-level security policy for the enterprise?**
   a. Senior management and all line management.
   b. All staff within the enterprise.
   c. Third parties that have access to the enterprise's information systems.
   d. All of the above.

7. **Which of these security documents is *NOT* mandatory?**
   a. A policy.
   b. A standard.
   c. A guideline.
   d. A procedure.

8. **Which of the following statements best describes an information security architecture?**
   a. A technical overview of assurance controls applied within the enterprise.
   b. A framework of assurance controls that can be applied across the enterprise to protect its information assets.
   c. The physical security controls applied within security locations.
   d. A blueprint for future security controls.

9. **Which of the following is the security standard that applies to the accreditation of security controls within products?**
   a. ISO/IEC 27001.
   b. ISO/IEC 15408.
   c. ISO/IEC 9000.
   d. ISO/IEC 13335.

10. **Privacy legislation is in place to protect the rights of:**
    a. Criminals.
    b. Companies.
    c. The individual.
    d. Data protection officers.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.

11. Which of the following is *NOT* a phase in incident management?

a. Assessment.
b. Investigation.
c. Reporting.
d. Elimination.

REFERENCES

Hughes, B., Ireland, R., West, B., Smith, N and Shepherd, D. I. (2019) *Project Management for IT-related Projects*, BCS.

NIST Cyber Security Framework: www.nist.gov/cyberframework

NPCC (2012) *Good Practice Guide for Digital Evidence*. National Police Chiefs' Council.

Copyright © 2013. BCS Learning & Development Limited. All rights reserved.

Taylor, A., Alexander, D., Finch, A., & Sutton, D. (2013). Information security management principles. BCS Learning & Development Limited.
Created from think on 2026-10-19 22:30:40.